

AVEVA (Wonderware + OSIsoft PI) Firmware Attack Surface & Detection Brief

Scope: ~7 product lines (AVEVA System Platform / ArchestrA, AVEVA InTouch HMI, AVEVA Plant SCADA (formerly Citect SCADA), AVEVA Edge (formerly InduSoft Web Studio), AVEVA Historian (formerly Wonderware Historian), AVEVA PI Server / PI AF / PI Vision / PI Web API, AVEVA Insight + Edge Data Store) across 5 architecture classes — **research-only brief; firmware extraction is pending** (no on-host catalog yet, no `firmware-staging/AVEVA/` rootfs walk performed). Findings combine vendor PSIRT bulletins, CISA ICS advisories, NVD CVE records, and named research from Claroty Team82, Forescout Vedere Labs, and Dragos. This brief primes the analyst queue for the moment AVEVA installer payloads (ArchestrA setup bundles, PI Server `.msi`, AVEVA Edge `.exe`, PI Vision IIS bundles) land in `firmware-staging/AVEVA/`.

Purdue layer mapping: AVEVA System Platform / Plant SCADA / InTouch SCADA servers (Group A) and PI Server / Historian (Group B) sit at **Purdue L3 (Site Operations)**; InTouch HMI runtime on a panel PC and AVEVA Edge panel runtimes (Group C) live at **Purdue L2 (Area Supervisory)**; AVEVA Insight Edge Data Store / Publisher (Group D) is a textbook **L3.5 IDMZ** appliance bridging to **L4/L5** cloud; ArchestrA IDE / PI Builder / engineering workstations (Group E) live at **Purdue L3** EWS. See [purdue-l1-basic-controllers-brief.md](#) (downstream RTUs the SCADA layer talks to), [purdue-l2-area-supervisory-brief.md](#) (HMI panels), [purdue-l3-site-operations-brief.md](#) (SCADA + EWS + Historian), [purdue-l35-it-ot-boundary-brief.md](#) (Insight Edge Data Store + cloud agents), and [purdue-safety-systems-brief.md](#) for safety-system interlocks the InTouch operator surface can mask.

Architecture grouping (drives the threat model, not the SKU)

Class	Purdue layer	Products	Stack	Catalog depth
A. SCADA / HMI Server	L3 Site Operations	AVEVA System Platform (ArchestrA Galaxy + GR node), AVEVA Plant SCADA (formerly Citect), AVEVA InTouch HMI server	Windows Server + .NET + ArchestrA Bootstrap service + SuiteLink (TCP/5413) + FastDDE + WindowViewer	research-only (pending)
B. PI System / Historian	L3 Site Operations	AVEVA PI Server (PI Data Archive), PI Asset Framework (PI AF), PI Vision, PI Web API,	Windows Server + SQL Server + IIS + PI Network	research-only (pending)

Class	Purdue layer	Products	Stack	Catalog depth
		AVEVA Historian (formerly Wonderware Historian on SQL Server)	Manager (TCP/5450) + AF SDK	
C. Edge / panel HMI runtime	L2 Area Supervisory	AVEVA Edge (formerly InduSoft Web Studio), InTouch Edge HMI runtime, EdgeView runtime on panel PC	Windows / Windows Embedded / WinCE / Linux runtime; CESServer.exe + Studio Mobile Access Web Server	research-only (pending)
D. Insight Cloud + Edge Data Store	L3.5 IDMZ + L4/L5 cloud	AVEVA Insight (Azure SaaS), Insight Publisher / Edge Data Store, OPC UA gateway	.NET service + MQTT/HTTPS egress to <code>*.connect.aveva.com</code>	research-only (pending)
E. Engineering / Config tooling	L3 EWS	Archestra IDE, InTouch WindowMaker, PI Builder (Excel add-in), PI System Explorer, Plant SCADA Project Editor	Windows admin workstation binaries	research-only (pending)

Group A — SCADA / HMI Server (System Platform + Plant SCADA + InTouch) — Purdue L3 (Site Operations)

Direct attack surface (per AVEVA install docs + Archestra security guide):

SuiteLink TCP/5413 (Wonderware data-broker, no native auth) ·
 Archestra Bootstrap service (TCP/5413 + dynamic RPC) ·
 FastDDE / NetDDE (legacy data exchange) ·
 Plant SCADA IPC ports TCP/2073-2074 · OPC DA/UA · WindowViewer client RPC ·
 NetBIOS / SMB (Galaxy database file shares) · MS SQL Server (Galaxy Repository, default 1433)

System Platform and Plant SCADA run **on top of Windows Server with Galaxy Repository / Plant SCADA runtime as SYSTEM-privileged Windows services** — every Group A vulnerability is fundamentally a Windows server compromise that hands the attacker the SCADA runtime.

Confirmed CVEs / advisories:

CVE	CVSS	Product	Vector	Status
Archestra / System Platform improper-auth class (2023)	—	AVEVA System Platform 2020 R2 SP1 and earlier	Improper authentication on Archestra service → unauth interaction with Galaxy	AVEVA PSIRT index

CVE	CVSS	Product	Vector	Status
CVE-2020-25182	7.8	InTouch Access Anywhere / System Platform	Insecure DLL search-path → privilege escalation / RCE	ICSA-21-021-04
AVEVA Plant SCADA hardcoded-credential class (2022)	—	AVEVA Plant SCADA 2020 R2 + earlier	Hardcoded credentials on internal service	AVEVA PSIRT index
Stuxnet WinCC pivot pattern	—	Wonderware lateral path (analogue)	Documented Galaxy share traversal — same SMB/share pivot as WinCC	Reference: Fore Scout Vedere Labs

Top attack vector (MITRE ATT&CK ICS): [T0866 Exploitation of Remote Services](#) into the Archestra Bootstrap service, chained to [T0836 Modify Parameter](#) via SuiteLink writes — the canonical Wonderware lateral-pivot pattern Stuxnet generalized.

Group B — PI System / Historian — Purdue L3 (Site Operations)

Direct attack surface (per OSIsoft / AVEVA PI System Hardening Guide):

PI Network Manager TCP/5450 (PI client ↔ Data Archive; PI trust + Windows-integrated auth) •
 PI Web API HTTPS/443 (OData over IIS) • PI Vision HTTPS/443 (IIS web app) •
 AF SDK over RPC • SQL Server backend (Historian) • OPC UA gateway • PI Connector services (varies)

PI Server's historical "PI trust" mechanism — IP/hostname-based authentication — is still found enabled on legacy deployments and is the canonical bypass path that pre-dates Windows-integrated auth.

Confirmed CVEs / advisories:

CVE	CVSS	Product	Vector	Status
PI Asset Framework Server vulnerability class (2024)	—	PI Asset Framework Server	AF Server class — privilege / parameter handling	AVEVA PSIRT index
AVEVA Edge Data Store unauth RCE class (2024)	High	AVEVA Edge Data Store (PI Edge family)	Unauth RCE	AVEVA PSIRT index
PI Vision / PI Web API XSS family	—	PI Vision, PI Web API	Stored / reflected XSS in display rendering	AVEVA PSIRT index

CVE	CVSS	Product	Vector	Status
Claroty Team82 — Wonderware / PI research	—	PI Server + System Platform	Family of mgmt-plane bugs documented across 2020- 2024	Claroty Team82 research

Top attack vector (MITRE ATT&CK ICS): [T0866 Exploitation of Remote Services](#) against PI Web API, chained to [T0832 Manipulation of View](#) by injecting fabricated tag values into PI Vision dashboards — PI is the **process intelligence layer**, so its compromise leaks and rewrites the entire plant model.

Group C — Edge / panel HMI runtime — Purdue L2 (Area Supervisory)

InTouch Edge HMI and AVEVA Edge (InduSoft Web Studio) runtimes execute on hardened Windows / Windows Embedded / WinCE panel PCs and on Linux edge runtimes — operator-facing at L2. Studio Mobile Access (HTTP/80 or HTTPS/443 + a TCP listener around 1234 by default) is the historical web-exposure surface that has generated the bulk of InduSoft / AVEVA Edge CVEs.

Confirmed CVEs / advisories:

CVE	CVSS	Product	Vector	Status
AVEVA Edge Data Store unauth RCE class (2024)	High	AVEVA Edge Data Store	Unauth RCE on edge data service	AVEVA PSIRT index
InduSoft Web Studio CEServer family	—	InduSoft / InTouch Edge	Historical stack-overflow / path- traversal class in CEServer.exe	CISA ICS advisories index
InTouch Edge HMI PSIRT class	—	InTouch Edge HMI runtime	Multiple advisories on remote agent / Mobile Access	AVEVA PSIRT

Top attack vector (MITRE ATT&CK ICS): [T0866 Exploitation of Remote Services](#) against CEServer / Mobile Access, then [T0833 Modify Control Logic](#) via the local tag database driving downstream PLC writes.

Group D — AVEVA Insight Cloud + Edge Data Store — Purdue L3.5 IDMZ + L4/L5

Insight Edge Data Store / Publisher runs in the IDMZ, polls OPC UA / SuiteLink upstream from PI / System Platform, and pushes telemetry via TLS to *.connect.aveva.com (Azure). The attack surface is **outbound TLS exfiltration plus the on-prem gateway's local management UI**.

Confirmed CVEs / advisories: No widely-cited Insight Edge-specific CVE family at brief time — track [AVEVA PSIRT](#) and CISA's ICS advisory index for the `aveva-insight` keyword. Forescout's IDMZ research applies generically: see [Forescout Vedere Labs](#).

Top attack vector (MITRE ATT&CK ICS): [T0866 Exploitation of Remote Services](#) — the Insight gateway is a *legitimate* outbound TLS path from OT to cloud; abuse the trust path on the management plane rather than the egress protocol.

Group E — Engineering / Config tooling (ArchestrA IDE, PI Builder) — Purdue L3 EWS

Engineering workstations holding ArchestrA IDE, InTouch WindowMaker, PI System Explorer, and PI Builder hold the credentials and TLS trust to every Galaxy and PI Data Archive in the site. These are the **lateral movement crown jewels**: a single compromised EWS owns the historian and the SCADA. CVE-2020-25182 (DLL search-path) is a Group E foothold pattern. CISA-published Wonderware advisories ([ICSA-21-021-04](#)) and the AVEVA PSIRT advisory series all describe vectors that begin on this host class.

Water-utility deployment pattern (the primary use case)

Mid-sized municipal water/wastewater utilities deploy AVEVA InTouch HMI as the dominant control-center SCADA — typically on a single Windows Server pair running InTouch + a small ArchestrA Galaxy, talking SuiteLink and Modbus TCP down to Schneider/Allen-Bradley RTUs at lift stations and treatment plants. Older municipal deployments may still run **AVEVA Plant SCADA (formerly Citect)** — the same Group A surface, with the 2022 hardcoded-credential class explicitly in scope. **PI Server is rare in pure-water** (more common in refining) but **combined-cycle cogeneration and utility-scale water-and-power facilities use it** for cross-plant historian roll-up. Water-utility threat-modeling priority: Group A (InTouch + Plant SCADA on-prem servers) > Group E (engineer's laptop) > Group C (panel HMIs at remote lift stations, often on cellular backhaul) > Group D (cloud telemetry, where adopted). See [purdue-l1-basic-controllers-brief.md](#) for the downstream RTU layer InTouch drives.

Logging matrix (highest priority)

Top 8 — ordered by detection value per ingest dollar:

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	Windows Security (SCADA server)	EventID 4624 Type 3 to SCADA server outside engineering hours from non-EWS source	Lateral movement onto Galaxy / PI Data Archive	T0866 Exploitation of Remote Services
2	ArchestrA / Galaxy audit log	<code>GalaxyObject.Checkout</code> + <code>Deploy</code> outside change-window	Tampered AppEngine / template deploy	T0836 Modify Parameter
3	PI Server message log	<code>PI trust</code> add/modify, <code>PIAdmin</code> interactive login	Persistence on PI Data Archive	T0812 Default Credentials
4	IIS log (PI Vision / PI Web API)	Anomalous <code>GET /piwebapi/dataservers/</code> enumeration burst	PI tag / asset model scraping	T0866 Exploitation of Remote Services
5	Network IDS (Suricata/Zeek)	SuiteLink TCP/5413 from outside L3 SCADA VLAN	Direct ArchestrA exploit traffic	T0866 Exploitation of Remote Services
6	Network IDS	Modbus function codes 5/6/15/16 crossing L3→L2/L1 from a SCADA server with no scheduled change	Control-logic tamper via InTouch	T0833 Modify Control Logic
7	Sysmon on EWS	EventID 7 ImageLoad on <code>ArchestrA*.exe</code> / <code>WindowMaker.exe</code> / <code>PIBuilder*.exe</code> loading DLL from user-writable path	CVE-2020-25182-class DLL hijack	T0866 Exploitation of Remote Services
8	Sysmon on Insight Edge Data Store	Process tree where parent is Insight Publisher AND child is <code>powershell.exe</code> / <code>cmd.exe</code>	Cloud-bridge abuse via management plane	T0866 Exploitation of Remote Services

Secondary:

- AVEVA-native audit channels: ArchestrA Galaxy database audit log, InTouch alarm/event log, Plant SCADA audit trail, PI Server message log (`PIPC.log`), PI Audit Database, PI Web API request log, AVEVA Edge runtime trace. Forward all via Windows Event Forwarding or syslog.
- SQL Server audit on Galaxy Repository + Historian SQL: detect `sp_addlogin` / `sp_addrolemember` outside maintenance.
- OT-native anomaly: tag-write rate spike from InTouch runtime to a Modbus RTU with no operator UI interaction; sudden disable of an InTouch alarm group (mask-the-attack pattern, [T0832 Manipulation of View](#)); PI tag with a step-change that does not match any process model (fabricated historian data).
- Firewall: egress from SCADA server VLAN to anything other than the Insight Edge Data Store target subnet + WSUS — InTouch servers should never originate outbound to internet.

Specific zero-day-ish concerns for your dataset

1. **AVEVA Edge Data Store unauth RCE class (2024) is the single highest-priority untriaged surface.** Edge Data Store ships as part of multiple AVEVA Edge / PI Edge installer bundles — when the Group C catalog lands in `firmware-staging/AVEVA/`, the first hash check is whether any deployed Edge Data Store predates the AVEVA PSIRT fix line ([AVEVA PSIRT index](#)).
2. **ArchestrA improper-authentication class (2023).** A Group A vector that lets an unauth attacker on the SuiteLink VLAN interact with Galaxy. Map every System Platform install to its build number; anything below the 2020 R2 SP1 P02 fix line is exploitable on-LAN. This is the Stuxnet-style lateral path on modern firmware. Track via [AVEVA PSIRT index](#).
3. **Plant SCADA hardcoded-credential class (2022) is still in long-tail municipal water deployments.** Plant SCADA installs from before the 2022 patch are the highest-priority audit target in water utilities running the older brand. Coverage gap: the credential constant is in the installer binary, so a Group A binary catalog can hash-match the vulnerable build directly.
4. **PI Vision / PI Web API XSS chain into ArchestrA write.** PI Vision displays embedded in operator dashboards have historically had reflected-XSS bugs (see [AVEVA PSIRT index](#)). Chain a stored XSS in a PI display with an operator's cached PI Web API session → forge a tag write → and if that tag is bridged to ArchestrA, you have an HMI-rendered control-logic write ([T0833 Modify Control Logic](#)) that looks like a legitimate operator action ([T0832 Manipulation of View](#) on the SOC side). Detection only via IIS log anomaly + ArchestrA audit correlation.
5. **InTouch on Windows panel PCs is rarely patched** because every patch is an operator-disrupting reboot. Assume the InTouch HMI catalog will reveal builds 2+ years behind the AVEVA fix line; Group C will dominate the "high CVSS still deployed" tail in any real-world municipal water audit. CVE-2020-25182 DLL-hijack is the foothold pattern to expect.

Sources

- [AVEVA Cyber Security Updates / PSIRT portal](#)
- [CISA ICS Advisory ICSA-21-021-04 — Wonderware InTouch \(CVE-2020-25182\)](#)
- [NVD — CVE-2020-25182](#)
- [CISA ICS Advisories index](#)
- [Claroty Team82 — ICS/OT research](#)
- [ForeScout Vedere Labs — Research Labs](#)
- [Dragos — ICS threat intelligence blog](#)
- [OSIsoft / AVEVA PI System documentation](#)

- [MITRE ATT&CK for ICS — T0812 Default Credentials](#)
- [MITRE ATT&CK for ICS — T0832 Manipulation of View](#)
- [MITRE ATT&CK for ICS — T0833 Modify Control Logic](#)
- [MITRE ATT&CK for ICS — T0836 Modify Parameter](#)
- [MITRE ATT&CK for ICS — T0866 Exploitation of Remote Services](#)
- [CISA/NSA/FBI/ASD — Best Practices for Event Logging and Threat Detection \(2024\)](#)